

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☒	☐	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations:

The following recommendations are provided for the IT manager to communicate to stakeholders, in order to reduce risk to assets and improve Botium Toys' overall security posture. Items are grouped by urgency, reflecting the potential risk or regulatory fines associated with continued non-compliance.

High priority — address immediately:

- Implement least privilege and separation of duties so employees only access the systems and data (including cardholder data and PII/SPII) required for their role. This directly addresses PCI DSS and SOC confidentiality gaps.
- Encrypt credit card data at rest, in transit, and during processing. The lack of encryption is the single largest PCI DSS compliance gap and the biggest driver of the current high risk score.

- Deploy an intrusion detection system (IDS) to detect anomalous or malicious traffic that the firewall alone cannot catch.
- Establish a disaster recovery plan and begin regular backups of critical data. Currently, a single incident (ransomware, hardware failure, natural disaster) could result in permanent data loss with no path to recovery.
- Strengthen the password policy to require a minimum of 8 characters, a mix of upper/lowercase letters, at least one number, and at least one special character, and deploy a centralized password management system to enforce it and reduce help-desk burden.

Medium priority — address in the near term:

- Classify and inventory all data assets (a core requirement of the NIST CSF Identify function and of GDPR) so the organization knows what data exists, where it lives, and how sensitive it is.
- Formalize a regular monitoring and maintenance schedule for legacy systems, with clearly defined intervention steps, rather than relying on ad hoc, undocumented processes.

Lower priority — maintain and continue:

- Continue current practices that are already working well: the firewall, antivirus software, physical locks, CCTV surveillance, fire detection/prevention, and the established GDPR breach-notification plan and privacy policies.